

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC102 – INFORMATION SECURITY GOVERNANCE

WEEK 2 PRACTICAL LABORATORY

NEXUSTECH SOLUTIONS – POLICY OVERHAUL SIMULATION

Role: Information Security Manager

Module: Module 2 – Developing Security Policies and Procedures

Week: Week 2

Policy Manual Version: 1.0

Date: 18 September 2026

EVIDENCE BUNDLE 1 – SECURITY POLICY HIERARCHY

Task 1: Policy Hierarchy and Categorisation

1.1 Documentation Hierarchy

Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Policy	Establishes organisational direction, rules, responsibilities and required security outcomes	Highest	Mandatory	High-level
Standard	Defines specific minimum requirements that must be met to support a policy	High	Mandatory	Medium / specific
Procedure	Provides step-by-step instructions for carrying out a required activity	Operational	Mandatory where applicable	Detailed

Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Guideline	Provides recommended practices to help users make appropriate decisions	Supporting	Recommended	Flexible / practical

Policy

A **policy** states what the organisation requires and establishes the overall direction.

Example:

“NexusTech employees must use MFA when accessing the corporate network remotely.”

Standard

A **standard** establishes a specific measurable requirement that supports a policy.

Example:

“Corporate laptops must use full-disk encryption.”

Procedure

A **procedure** explains exactly how an activity is performed.

Example:

“To configure MFA, download the approved Authenticator application, scan the QR code and enter the verification code.”

Guideline

A **guideline** provides recommended good practice but normally allows some flexibility.

Example:

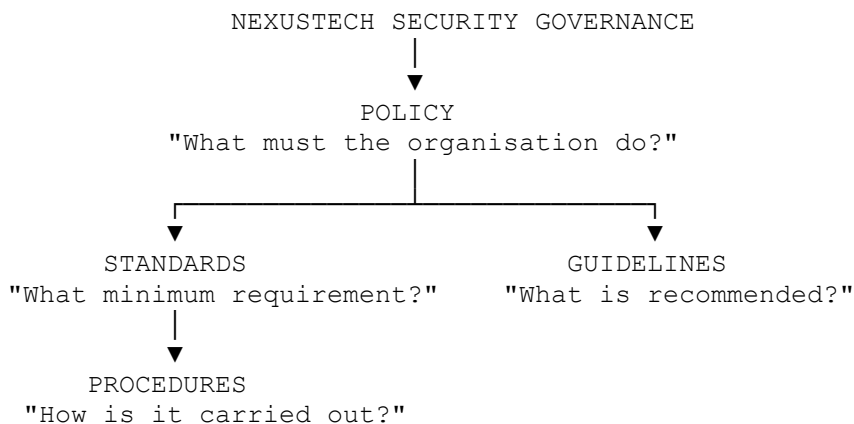
“Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.”

1.2 Categorisation of the Eight Statements

No.	Statement	Classification	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	It establishes a mandatory organisational security requirement without explaining how to implement it.

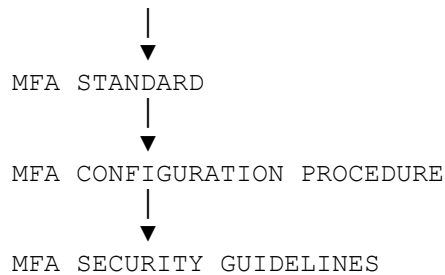
No.	Statement	Classification	Justification
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code and enter the six-digit code.	Procedure	It provides sequential instructions for completing a specific technical activity.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	The wording “recommended” makes this advisory rather than a mandatory requirement.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	It expresses a broad organisational security commitment and direction.
5	All corporate laptops must have full-disk encryption enabled using BitLocker or FileVault.	Standard	It defines a specific mandatory technical security requirement and approved technologies.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	The word “should” indicates recommended behaviour rather than a strict mandatory requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	It directs users to take a specific action when a defined event occurs.
8	Passwords must be a minimum of 14 characters and contain uppercase, lowercase, number and special character.	Standard	It establishes measurable technical requirements for passwords.

1.3 Security Policy Hierarchy Diagram



Example Flow

ACCESS CONTROL POLICY



This hierarchy resolves the problem identified by the Information Security Manager: the old “IT Rules” document mixed policy intent, technical instructions and recommendations in one document. The new structure separates these levels so that accountability, enforcement and maintenance are clearer.

EVIDENCE BUNDLE 2 – ACCEPTABLE USE POLICY

NEXUSTECH SOLUTIONS

ACCEPTABLE USE POLICY

Document Control

Field	Details
Policy Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Status	Approved

1. Purpose

The purpose of this Acceptable Use Policy is to establish clear requirements for the appropriate and secure use of NexusTech Solutions' information systems, devices, networks, applications and other technology resources.

The policy is intended to reduce malware, information-security, compliance and operational risks arising from inappropriate use of company resources.

2. Scope

This policy applies to:

- all NexusTech employees;
- contractors and consultants;
- temporary workers;
- authorised third parties;
- company-owned computers and mobile devices;
- corporate networks;
- company accounts;
- applications;
- cloud services; and
- other technology resources provided or authorised by NexusTech.

3. Roles and Responsibilities

3.1 Users

Users shall:

- comply with this policy;
- protect their credentials;
- use company resources responsibly;
- install only authorised software;
- protect company information;
- report suspected security incidents; and
- cooperate with security investigations.

3.2 IT and Information Security

IT/Security shall:

- implement appropriate technical safeguards;
- manage approved software and systems;
- monitor security risks;
- investigate suspected misuse; and
- provide security guidance and awareness.

3.3 Managers

Managers shall:

- ensure employees understand applicable requirements;
- approve legitimate business access and software requirements;

- address policy violations; and
- escalate repeated or serious non-compliance.

3.4 Human Resources

HR shall:

- support employee onboarding and policy acknowledgement;
- coordinate disciplinary processes where required; and
- ensure policy requirements are incorporated into relevant employee processes.

4. Acceptable Use

Users shall use NexusTech technology resources for legitimate business purposes.

Reasonable personal use may be permitted provided that it:

1. does not interfere with work responsibilities;
2. does not consume excessive company resources;
3. does not create a security risk;
4. does not violate company policy;
5. does not involve unlawful activity; and
6. does not result in inappropriate disclosure of company information.

Users shall protect company devices from unauthorised access and shall lock devices when leaving them unattended.

Users shall use company systems in accordance with applicable security requirements.

5. Prohibited Activities

Users **must not**:

1. Attempt to gain unauthorised access to NexusTech systems, accounts or data.
2. Share passwords, authentication tokens or other authentication credentials.
3. Disable, bypass or deliberately interfere with security controls.
4. Download or install unauthorised software.
5. Introduce malware or other malicious code into company systems.
6. Use company resources to conduct unlawful activities.
7. Access, modify, copy or disclose information without appropriate authorisation.
8. Use company resources to harass, threaten or intimidate others.
9. Use company systems to distribute malicious, fraudulent or deceptive content.
10. Store company-sensitive information in unauthorised personal cloud-storage accounts.
11. Connect unauthorised devices to company systems where doing so creates a security risk.

12. Use company resources in a way that creates unreasonable security, legal or compliance risks.

6. Software and Applications

Users shall install and use only software authorised by NexusTech.

Where a business need requires software that is not currently approved, the user shall submit a request through the approved IT process.

Users shall not download software from untrusted sources onto company devices.

7. Internet and Network Use

Company network resources shall be used responsibly.

Users shall not deliberately attempt to circumvent network-security controls, monitoring mechanisms or access restrictions.

Users travelling on company business should use secure and approved methods of accessing corporate resources.

8. Email and Communication

Users shall not use company email or communication systems for:

- phishing;
- fraud;
- harassment;
- unauthorised disclosure of confidential information;
- distribution of malware; or
- other prohibited activities.

Suspicious messages or suspected phishing attempts shall be reported through the approved security-reporting process.

9. Protection of Company Information

Users shall protect NexusTech information from unauthorised access, disclosure, modification or loss.

Sensitive company information shall only be stored, transmitted and shared through approved systems and services.

Users shall not transfer sensitive company information to personal storage services unless explicitly authorised.

10. Monitoring

NexusTech may monitor the use of company systems and resources in accordance with applicable laws, policies and legitimate business requirements.

Monitoring may be used to investigate security incidents, detect misuse, protect company resources and support compliance.

11. Compliance and Enforcement

Failure to comply with this policy may result in:

- additional security training;
- removal or restriction of system access;
- corrective action;
- disciplinary action;
- contractual consequences; or
- legal action where appropriate.

The response shall be proportionate to the nature and severity of the violation.

12. Exceptions

Exceptions may be granted only where there is a legitimate business requirement.

An exception request must:

1. identify the requirement being excepted;
2. explain the business justification;
3. identify the associated security risk;
4. identify appropriate compensating controls;
5. receive approval from the authorised authority; and
6. include an expiry or review date.

Exceptions shall be documented and periodically reviewed.

13. Approval and Review

This policy is approved by the CEO and owned by the Information Security Manager.

It shall be reviewed annually and earlier when significant changes occur to:

- technology;
- business operations;
- security risks;
- legal or compliance requirements;
- company infrastructure; or
- security incidents.

Approved by: Marcus Vance, CEO

Effective Date: 18 September 2026

Next Review: 18 September 2027

EVIDENCE BUNDLE 3 – USER ACCESS REQUEST PROCEDURE

NEXUSTECH SOLUTIONS

USER ACCESS REQUEST PROCEDURE

Version: 1.0

Owner: Information Security Manager / IT Helpdesk

Approval Authority: IT Management

Effective Date: 18 September 2026

1. Purpose

This procedure establishes a consistent process for requesting, approving, provisioning, documenting and closing user access to NexusTech systems.

It replaces informal access requests through email and chat with a controlled and auditable process.

2. Scope

This procedure applies to requests for access to:

- corporate applications;
- networks;
- databases;
- cloud services;
- file systems;
- business systems; and
- other NexusTech information resources.

3. Prerequisites

Before processing an access request, the Helpdesk technician must have access to:

- the approved service-desk/ticketing system;
- the relevant identity-management system;
- the applicable access-control standards;
- approved role definitions; and
- authorised approvers.

The requester must provide sufficient information to identify the user, required system and business justification.

4. Procedure

Step 1 – Receive the Request

The requester must submit the access request through the approved ticketing or workflow system.

Do not process ordinary access requests received only through informal email, instant messaging or verbal requests.

Step 2 – Check the Request

The Helpdesk technician shall confirm that the ticket contains:

- user's name;
- department;
- role/job function;
- requested system;

- requested access level;
- business justification;
- manager;
- relevant data/system owner; and
- required start date where applicable.

If required information is missing, return the request to the requester for completion.

Step 3 – Verify the User

Confirm that the requested account belongs to an authorised NexusTech employee, contractor or other approved user.

For new employees, confirm that the user has completed the applicable onboarding requirements.

Step 4 – Verify Manager Approval

Check the ticket for approval from the user's authorised manager.

Do not provision access if the required approval is missing.

Step 5 – Verify Data/System Owner Approval

Where the requested resource contains sensitive information or requires elevated privileges, confirm approval from the appropriate system or data owner.

Step 6 – Determine the Appropriate Role

Identify the standard role that corresponds to the user's job responsibilities.

Use role-based access wherever available.

Do not assign permissions beyond what is required for the user's legitimate responsibilities.

Step 7 – Perform Least-Privilege Check

Before provisioning access, verify that:

- the requested access is necessary;
- the selected role is appropriate;
- privileged access is not being unnecessarily granted; and
- the permissions are consistent with the user's responsibilities.

If excessive access is requested, obtain clarification or approval before continuing.

Step 8 – Create or Update the Account

Using the authorised identity-management process:

1. create the account if the user does not have one;
2. assign the approved role;
3. apply required authentication controls;
4. enable only the approved resources; and
5. avoid granting additional permissions that were not approved.

Step 9 – Verify Access

Confirm that the account has been provisioned correctly.

Where practical, verify that the user can access the approved resource and cannot access resources outside the approved scope.

Step 10 – Notify the User and Manager

Notify the user that access has been provisioned.

Where appropriate, notify the manager that the request has been completed.

Do not send passwords or sensitive authentication information through insecure communication channels.

Step 11 – Capture Evidence

Update the access-request ticket with:

- approval evidence;
- date of provisioning;
- technician responsible;
- role assigned;
- system accessed;
- relevant verification evidence; and
- any exceptions or additional approvals.

Step 12 – Close the Ticket

Once all required activities are complete:

1. confirm the request has been fulfilled;
2. confirm evidence has been recorded;
3. document any issues;
4. notify the requester; and
5. close the ticket.

5. Emergency or Exceptional Requests

Emergency access may be granted when necessary to protect business operations or respond to a security incident.

Emergency access shall:

- be authorised by the designated emergency approver;
- be limited to the minimum required privileges;
- be time-limited where technically possible;
- be documented in the ticketing system; and
- undergo retrospective review.

Emergency access shall not be used to avoid the normal approval process for convenience.

6. Record Retention and Audit Trail

All access requests and approvals shall be retained in the approved ticketing or access-management system according to NexusTech's record-retention requirements.

The audit trail shall allow NexusTech to determine:

- who requested access;
- who approved it;
- what access was granted;
- when it was granted;
- who provisioned it; and
- whether an exception was involved.

7. Procedure Controls

Access requests shall be periodically reviewed to identify:

- excessive permissions;
- unauthorised access;
- repeated exceptions;
- incomplete approvals;

- dormant accounts; and
- process weaknesses.

EVIDENCE BUNDLE 4 – COMMUNICATION AND TRAINING PLAN

NEXUSTECH ACCEPTABLE USE POLICY ROLLOUT PLAN

The AUP and User Access Request Procedure have been approved by the CEO. Simply distributing the documents is insufficient; users must understand and demonstrate the required behaviours.

4.1 Communication and Training Plan

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	Understand acceptable use, prohibited activities, software restrictions and information protection requirements	Email, town hall, intranet and mandatory learning module	HR + Information Security	Week 1	Digital acknowledgement	≥95% training completion
IT Staff	Understand AUP requirements and how they affect technical administration and access management	Technical briefing + training module	Information Security Manager	Week 1	Training attendance	≥95% knowledge-check score

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
Managers	Understand their responsibility for enforcing policy and approving legitimate access	Management briefing	Information Security Manager	Week 1	Manager attestation	100% manager completion
HR	Understand onboarding, acknowledgment and disciplinary responsibilities	HR briefing	Information Security + HR	Week 1	Meeting record	100% HR participation
New Employees	Understand AUP requirements before receiving access to company resources	Onboarding training	HR + IT	At onboarding	Signed/digital acknowledgment	100% acknowledgment before access
Contractors	Understand applicable acceptable-use requirements before receiving company access	Email + onboarding briefing	Procurement/Manager	Before access	Contractual acknowledgment	100% acknowledgment

4.2 Rollout Timeline

Day 1 – Announcement

The CEO announces the approved AUP and explains why the policy has been introduced.

Day 2 – Policy Publication

The AUP is published on the approved company intranet or policy repository.

Employees receive a notification containing:

- policy purpose;
- effective date;
- training deadline;
- acknowledgement requirement; and
- reporting contact.

Days 3–5 – Training

Mandatory training is delivered to employees.

Training includes practical examples involving:

- unauthorised software;
- personal use;
- phishing;
- sensitive information;
- personal cloud storage;
- acceptable internet use; and
- reporting suspected incidents.

End of Week 1 – Acknowledgement

Employees complete a digital acknowledgement confirming that they have read and understood the policy.

Week 2 – Follow-up

Information Security reviews:

- training completion;
- acknowledgement rates;
- knowledge-check results; and
- questions raised by employees.

Employees who have not completed training receive reminders.

Week 3 – Management Review

Managers receive a compliance report identifying outstanding users and recurring areas of misunderstanding.

Ongoing – Reinforcement

Important requirements are reinforced through:

- periodic awareness messages;
- onboarding;
- refresher training;
- security newsletters; and
- lessons learned from security incidents.

4.3 Acknowledgement Mechanism

Each employee shall complete an electronic acknowledgement stating:

“I confirm that I have received, read and understood the NexusTech Acceptable Use Policy and agree to comply with its requirements.”

The acknowledgement shall be recorded in the approved HR or learning-management system.

4.4 Rollout Effectiveness Measures

Measure 1 – Training Completion Rate

Target: At least 95% of affected personnel complete mandatory training by the deadline.

Measure 2 – Policy Acknowledgement Rate

Target: At least 95% of affected personnel acknowledge the policy.

Measure 3 – Knowledge-Check Rate

Target: At least 90% of participants achieve the required assessment score.

Measure 4 – Repeat Questions / Violations

Information Security shall monitor repeated misunderstandings and policy violations after rollout.

A high level of repeated misunderstanding shall trigger additional communication or targeted training.

4.5 Non-Compliance Escalation

The escalation process shall be:

Missed Training / Acknowledgement

↓

First Reminder
↓
Second Reminder
↓
Manager Escalation
↓
HR Escalation
↓
Access Restriction / Corrective Action

Repeated or deliberate violations may be escalated directly to management and HR depending on severity.

EVIDENCE BUNDLE 5 – POLICY REVIEW AND MAINTENANCE MEMO

POLICY REVIEW MEMORANDUM

To: Information Security Steering Committee
From: Information Security Manager
Subject: Review of NexusTech Acceptable Use Policy
Date: 18 September 2027
Policy: Acceptable Use Policy, Version 1.0
Proposed Action: Initiate policy review and revision

Memorandum

The NexusTech Acceptable Use Policy should be formally reviewed because two significant events have occurred since its approval. First, NexusTech migrated its primary database to AWS, introducing a major change to the organisation's technology environment and cloud-service usage. This creates a review trigger because the existing AUP should be assessed to determine whether its requirements adequately address cloud services, cloud-based data storage and the responsibilities of users when accessing company information through cloud platforms. Second, an employee shared a sensitive document through a personal cloud-storage account. This security incident indicates that the existing requirements concerning storage and sharing of company information may require stronger clarification and reinforcement.

The review should begin with consultation involving Information Security, IT, the database/cloud team, relevant system and data owners, HR, Legal/Compliance and business managers. The review team should examine the AWS migration, the incident report, relevant access and cloud-security controls, previous policy violations, employee questions and training results. A risk assessment should then determine whether existing AUP requirements adequately address personal cloud storage, approved cloud services and handling of sensitive information. Evidence from the review should be documented and used to determine the required policy changes.

Two specific updates are recommended. **First**, the AUP should explicitly prohibit users from storing or sharing sensitive NexusTech information through personal cloud-storage accounts unless an authorised exception has been approved. **Second**, the AUP should state that company information may only be stored or shared through NexusTech-approved cloud services and applications, subject to applicable security requirements. The revised policy should remain owned by the Information Security Manager and follow the established approval route to the CEO, Marcus Vance, as approval authority. The policy should continue to receive an annual review, with an **early review triggered by major technology or cloud-environment changes, significant security incidents, material changes to business operations, or changes to relevant compliance requirements.**